App Vault

Arquitetura, segurança, instalação e operação · desktop 1.1.0 · servidor 0.1.0 · outubro de 2026

1. Visão geral

O App Vault guarda credenciais de plataformas de dados (bancos, SFTP, APIs, painéis, SSH, nuvem) separadas por ambiente (Produção, Homologação, Desenvolvimento) num arquivo único e criptografado. Ele tem duas partes, com públicos diferentes:

Componente	Para quem	Onde roda	Situação
App Vault Protection (desktop)	Pessoas da equipe: cadastrar, consultar e copiar credenciais	Windows 10/11, por usuário, sem administrador	1.1.0 publicada nas Releases do GitHub
App Vault Server	Sistemas automatizados que precisam de credenciais sem ninguém para digitar senha	VM dedicada, Linux (recomendado) ou Windows Server	0.1.0 (MVP): usar com dados fictícios até a revisão de segurança
appvault_client.py	Código do sistema que consome as credenciais	VM do sistema, Python 3.10+	0.1.0, sem dependências

A ideia central: **as pessoas administram** os segredos no app desktop e **os sistemas só leem**, pelo servidor, o que a política permite. Nenhuma senha fica gravada na máquina do sistema, e a senha mestra do cofre não fica gravada em lugar nenhum.

2. Arquitetura

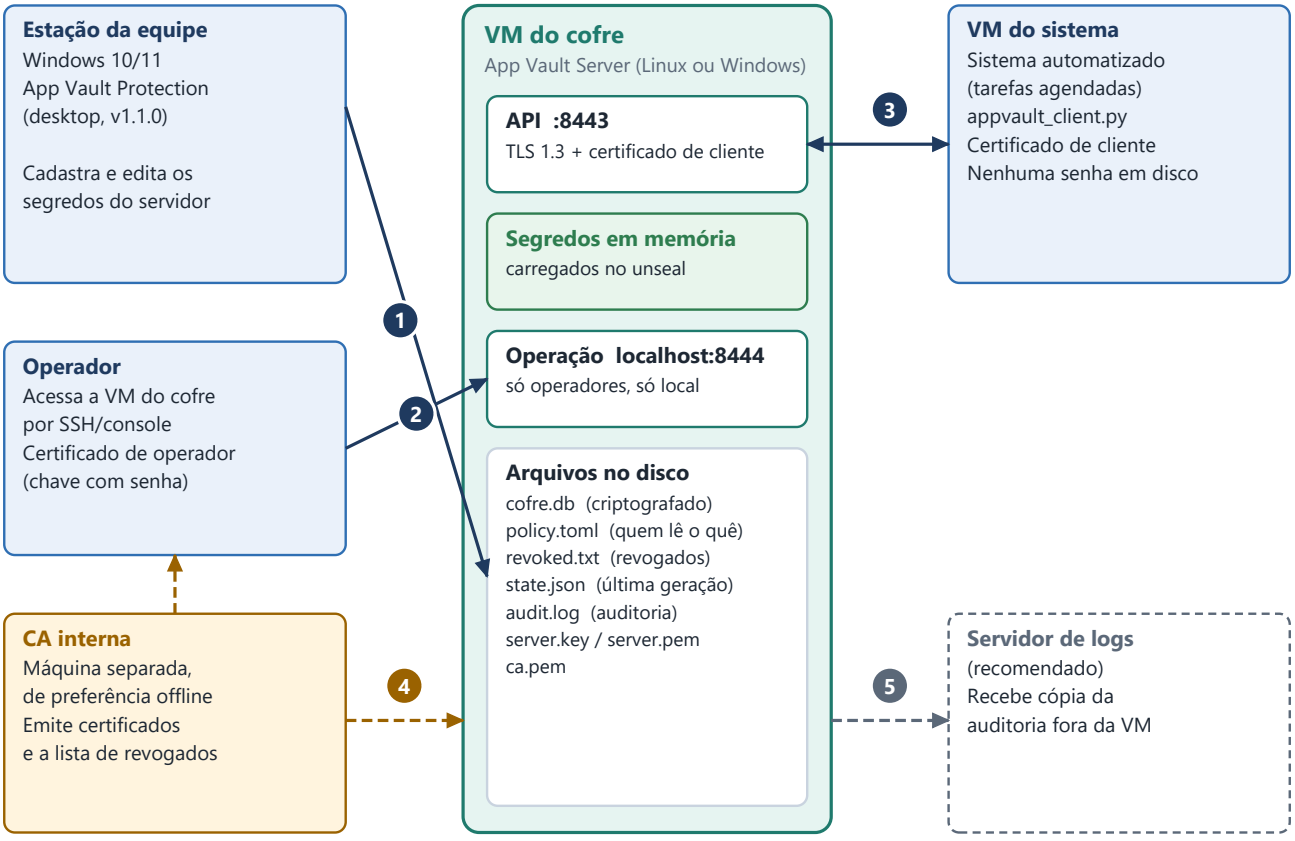


Figura 1. Componentes e fluxos. Linhas cheias: tráfego de produção; tracejadas: distribuição de certificados e cópia de logs.

	Fluxo	Como acontece
1	Publicar o cofre	A equipe gera o backup do cofre do servidor no app desktop e envia o `cofre.db` à VM do cofre por SFTP. O arquivo continua criptografado.
2	Desbloquear (unseal)	Um operador entra na VM e roda `unseal`, digitando a senha mestra. O servidor carrega os segredos na memória e fecha o arquivo. A senha não é guardada.
3	Ler um segredo	O sistema se conecta por TLS 1.3 com certificado de cliente (mTLS) e pede um segredo por ambiente e nome. Veja a Figura 2.
4	Emitir certificados	A CA interna emite os certificados do servidor, de cada sistema e de cada operador, e mantém a lista de revogados.
5	Copiar a auditoria	Cada evento também sai no log do serviço (journald ou WinSW), para ser encaminhado a um servidor de logs fora da VM.

3. O caminho de uma leitura

Cada pedido de segredo passa por estas verificações, nesta ordem. A política é conferida **antes** de procurar o segredo, então um sistema sem permissão não descobre se ele existe.

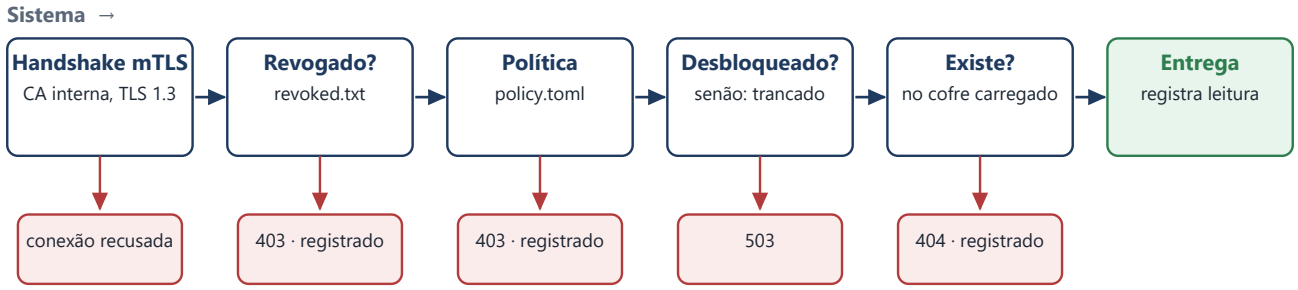


Figura 2. Verificações de uma requisição à API. Toda negação e toda leitura entram no log de auditoria, sem o valor do segredo.

4. Segurança

Cofre (arquivo) — compartilhado pelo desktop e pelo servidor

Proteção	Como
Senha mestra	scrypt (cerca de 128 MiB de memória por tentativa), mínimo de 12 caracteres
Criptografia	AES-256-GCM por segredo, com chave de dados aleatória embrulhada pela senha
Nomes ocultos	Nomes de ambientes e segredos não aparecem em texto claro no arquivo
Integridade	Manifesto HMAC detecta linhas apagadas, trocadas ou restauradas por fora
Versão do arquivo	Contador de geração autenticado (novo na 1.1.0); o servidor recusa arquivos antigos
Troca de senha	Gera chave de dados nova e recriptografa tudo

Servidor

Ameaça	Proteção
Cópia do disco da VM do cofre	O cofre continua criptografado e a senha mestra não está no disco
Invasão da VM do sistema	O invasor só alcança o que a política daquele sistema permite; revogue o certificado e troque essas credenciais

Ameaça	Proteção
Um sistema tentando ler segredos de outro	Política por certificado, conferida antes da busca
Escuta ou desvio na rede	TLS 1.3 com autenticação dos dois lados; só a CA interna é aceita
Republicação de um cofre antigo	Recusada; o servidor continua servindo a versão atual
Edição do log para esconder leituras	Cadeia de hashes detecta, e a cópia em outro servidor preserva os eventos
Uso indevido da operação	Porta só na interface local (localhost) e só com certificado de operador; operadores não leem segredos
Política ou lista de revogados corrompida	O servidor nega tudo até o arquivo ser corrigido

5. Instalação do app desktop (Windows)

Requisitos: Windows 10 ou 11 de 64 bits e cerca de 40 MB livres. Não precisa de Python nem de administrador. É preciso uma conta no GitHub com acesso de leitura ao repositório privado **ivamgf/app_vault_konektron_server**; peça ao responsável.

5.1 Baixar

Logado no GitHub, abra **github.com/ivamgf/app_vault_konektron_server/releases/latest** e, em **Assets**, baixe o instalador **AppVaultProtection-Setup-<versão>.exe** e o **SHA256SUMS.txt**. Se preferir, use o GitHub CLI:

```
gh release download --repo ivamgf/app_vault_konektron_server --pattern "*"
```

Baixe sempre da página de Releases, nunca de cópias recebidas por e-mail, chat ou pendrive.

5.2 Conferir a integridade

No PowerShell, na pasta do download:

```
(Get-FileHash .\AppVaultProtection-Setup-*.exe -Algorithm SHA256).Hash
Get-Content .\SHA256SUMS.txt
```

Os dois códigos precisam ser iguais. Se forem diferentes, **não instale**: apague o arquivo e baixe de novo.

5.3 Instalar

- Dê dois cliques no instalador e siga o assistente. Se quiser, marque o atalho na área de trabalho.
- Se aparecer **"O Windows protegeu o computador"** (o instalador ainda não tem assinatura digital), confira o código do passo 5.2 e clique em **Mais informações → Executar assim mesmo**.
- O app é instalado só para o seu usuário, em `%LOCALAPPDATA%\Programs\App Vault Protection`, e fica no Menu Iniciar.

5.4 Primeiro uso

- A tela **Novo cofre** cria o arquivo em `%LOCALAPPDATA%\AppVaultProtection\cofre.db`, numa pasta acessível só ao seu usuário.
- Defina a senha mestra: mínimo de 12 caracteres, de preferência uma frase longa. **Não há recuperação**; se ela for esquecida, os dados se perdem.
- Faça backups em **Cofre → Fazer backup...** e guarde a cópia num local restrito. Não guarde o cofre em pastas de rede, compartilhadas ou versionadas.

5.5 Atualizar, desinstalar e instalação silenciosa

Tarefa	Como
Atualizar	Baixe e confira a versão nova e instale por cima; os cofres são mantidos. Todos os computadores que usam o mesmo cofre devem estar na 1.1.0 ou mais nova.
Desinstalar	Configurações → Aplicativos → App Vault Protection → Desinstalar. Os cofres em `%LOCALAPPDATA%\AppVaultProtection` não são apagados.
Instalação silenciosa (TI)	Rode na sessão do próprio usuário, não como SYSTEM, porque a instalação é por usuário. Comandos abaixo.

```
# instalar (acrescente /TASKS="desktopicon" para criar o atalho na área de trabalho)
.\AppVaultProtection-Setup-1.1.0.exe /VERYSILENT /SUPPRESSMSGBOXES /NORESTART
# desinstalar
& "$env:LOCALAPPDATA\Programs\App Vault Protection\unins000.exe" /VERYSILENT /SUPPRESSMSGBOXES /NORESTART
```

6. Instalação do App Vault Server

> **Versão 0.1.0 (MVP).** Use com dados fictícios até a revisão de segurança independente. Nos exemplos, a VM do cofre é **cofre.interno** (IP <IP_DO_COFRE>), a VM do sistema tem o IP <IP_DO_SISTEMA>, o sistema se chama **sistema-x** e o operador, **op-01**. Troque pelos nomes reais.

Máquina	O que precisa
VM do cofre	Linux (recomendado) ou Windows Server, dedicada ao serviço; Python 3.11+ e o pacote cryptography
VM do sistema	Python 3.10+ e o arquivo appvault_client.py (sem dependências)
Máquina da CA	Python 3.11+ e cryptography; separada das VMs, de preferência desligada da rede
Estação da equipe	App Vault desktop 1.1.0 ou mais novo, para criar e editar o cofre do servidor

6.1 Criar a CA interna (máquina da CA)

Nos comandos a seguir, **python** é o Python do ambiente virtual criado aqui (no Windows, `.venv\Scripts\python`).

```
git clone https://github.com/ivamgf/app_vault_konektron_server.git && cd app_vault_konektron_server
python3 -m venv .venv && .venv/bin/pip install -r requirements-server.txt
python -m appvault_server ca init --dir ca --name "Konektron App Vault CA"
```

A senha da CA (mínimo de 12 caracteres) protege a chave da CA. Guarde a pasta **ca** e a senha fora das VMs: quem tiver as duas consegue emitir certificados aceitos pelo servidor.

6.2 Emitir os certificados

```
python -m appvault_server ca issue server   --dir ca --cn cofre.interno --san <IP_DO_COFRE> --out out/servidor
python -m appvault_server ca issue client   --dir ca --cn sistema-x --out out/sistema-x
python -m appvault_server ca issue operator --dir ca --cn op-01   --out out/op-01
```

Cada comando gera um certificado (.pem) e uma chave privada (.key), válidos por 397 dias. A chave do operador sempre tem senha. Leve cada arquivo **só** para onde ele é usado, por SCP/SFTP:

Arquivo	Destino
`ca/ca.pem`	VM do cofre e VM do sistema
`ca/revoked.txt`	VM do cofre
`out/servidor/cofre.interno.pem` e `.key`	VM do cofre
`out/sistema-x/sistema-x.pem` e `.key`	VM do sistema
`out/op-01/op-01.pem` e `.key`	Pasta pessoal do operador na VM do cofre

6.3 Preparar o cofre do servidor (app desktop)

- Em **Novo...**, crie um cofre **só para o servidor**, com senha mestra própria, diferente da do cofre pessoal.
- Cadastre apenas as credenciais de que os sistemas precisam, nos ambientes certos.
- Em **Cofre** → **Fazer backup...**, gere o `cofre.db` a ser publicado na VM do cofre.

6.4 Instalar na VM do cofre — Linux

Na VM, com o repositório (ou só `vault.py`, `appvault_server/`, `deploy/` e `requirements-server.txt`) e os arquivos dos passos anteriores na pasta atual:

```
# usuário, pastas e código
sudo useradd --system --home /var/lib/appvault --shell /usr/sbin/nologin appvault
sudo mkdir -p /opt/appvault /etc/appvault/tls /var/lib/appvault
sudo cp -r vault.py appvault_server requirements-server.txt /opt/appvault/
sudo python3 -m venv /opt/appvault/.venv
sudo /opt/appvault/.venv/bin/pip install -r /opt/appvault/requirements-server.txt

# configuração, certificados e cofre
sudo cp deploy/server.example.toml /etc/appvault/server.toml    # revise caminhos e portas
sudo cp deploy/policy.example.toml /etc/appvault/policy.toml    # operadores e o que cada sistema lê
sudo cp ca.pem revoked.txt /etc/appvault/tls/
sudo cp cofre.interno.pem /etc/appvault/tls/server.pem
sudo cp cofre.interno.key /etc/appvault/tls/server.key
sudo install -o appvault -g appvault -m 600 cofre.db /var/lib/appvault/cofre.db

# permissões: a chave do servidor só o serviço lê; o serviço só grava em /var/lib/appvault
sudo chown -R root:appvault /etc/appvault && sudo chmod -R u=rwX,g=rX,o= /etc/appvault
sudo chown appvault:appvault /etc/appvault/tls/server.key && sudo chmod 600 /etc/appvault/tls/server.key
sudo chown appvault:appvault /var/lib/appvault && sudo chmod 700 /var/lib/appvault
sudo chmod -R a+rX /opt/appvault

# validar, instalar o serviço e liberar a porta só para a VM do sistema
sudo -u appvault /opt/appvault/.venv/bin/python -m appvault_server check -c /etc/appvault/server.toml
sudo cp deploy/linux/appvault-server.service /etc/systemd/system/
sudo systemctl daemon-reload && sudo systemctl enable --now appvault-server
sudo ufw allow from <IP_DO_SISTEMA> to any port 8443 proto tcp
```

Não exponha a porta 8443 na internet; a 8444 já escuta só na interface local (localhost). Desative a swap ou use swap criptografada. Inclua cada operador no grupo `appvault` para que ele possa ler a configuração e o `ca.pem`. Os logs ficam em `journalctl -u appvault-server`.

6.5 Instalar na VM do cofre — Windows Server (alternativa)

- Instale o Python 3.11+ para todos os usuários e copie `vault.py`, `appvault_server\` e `requirements-server.txt` para `C:\AppVaultServer\`.
- Crie `C:\ProgramData\AppVaultServer\` com `server.toml`, `policy.toml`, a pasta `tls\` e o `cofre.db`, e ajuste os caminhos do server.toml.
- Crie um usuário local dedicado, sem administrador (ex.: `appvault-svc`).
- Baixe o **WinSW** (github.com/winsw/winsw), renomeie `WinSW-x64.exe` para `AppVaultServer.exe` e coloque-o em `C:\AppVaultServer\` junto com `deploy\windows\AppVaultServer.xml`.
- No Firewall do Windows, libere a porta 8443 só para o IP da VM do sistema.

```
py -3 -m venv C:\AppVaultServer\.venv
C:\AppVaultServer\.venv\Scripts\python.exe -m pip install -r C:\AppVaultServer\requirements-server.txt
icacls C:\ProgramData\AppVaultServer /inheritance:r /grant:r "Administradores:(OI)(CI)F" "appvault-svc:(OI)(CI)M"
C:\AppVaultServer\AppVaultServer.exe install
sc.exe config AppVaultServer obj= ".\appvault-svc" password= "<senha da conta>"
Start-Service AppVaultServer
```

6.6 Desbloquear (operador, na VM do cofre)

```
python -m appvault_server unseal -c /etc/appvault/server.toml --cert ~/op-01.pem --key ~/op-01.key
python -m appvault_server status -c /etc/appvault/server.toml --cert ~/op-01.pem --key ~/op-01.key
```

O comando pede a senha da chave do operador e a senha mestra do cofre. No Linux, use `/opt/appvault/.venv/bin/python`. Repita o `unseal` após cada reinício do serviço ou da VM, e sempre que publicar uma versão nova do cofre.

6.7 Configurar o sistema (VM do sistema)

Copie `ca.pem`, `sistema-x.pem` e `sistema-x.key` para uma pasta legível só pelo usuário que roda o sistema (`chmod 600` na chave), junto com o `appvault_client.py`. No código:

```
from appvault_client import AppVaultClient

cofre = AppVaultClient("https://cofre.interno:8443",
                       ca_file="/etc/sistema-x/appvault/ca.pem",
                       cert_file="/etc/sistema-x/appvault/sistema-x.pem",
                       key_file="/etc/sistema-x/appvault/sistema-x.key")

db = cofre.get("Produção", "Banco SIAFE")      # SealedError, AccessDeniedError, NotFoundError
conectar(host=db.host, port=int(db.port or 5432), user=db.username, password=db.password)
```

Não imprima nem registre em log os valores dos segredos.

6.8 Conferência final

Verificação	Resultado esperado
`check`	"Configuração ok", sem avisos sobre permissões de chaves
`status`	"Desbloqueado", com o número de segredos esperado
No sistema: `cofre.health()` e um `get()` de teste	`{"sealed": false}` e o segredo retornado
No sistema: `get()` de um segredo fora da política	`AccessDeniedError` (e um evento `read_denied` na auditoria)
`audit-verify`	"cadeia íntegra"
Porta 8443 a partir de outra máquina	Inacessível (bloqueada pelo firewall)

7. Operação

Tarefa	Quem	Como
Publicar nova versão do cofre	Equipe + operador	Backup no desktop, envio por SFTP, troca do arquivo e novo `unseal`; se falhar, a versão anterior continua no ar
Após reinício da VM ou do serviço	Operador	O servidor volta trancado: rodar `unseal`
Liberar um segredo a um sistema	Administrador	Editar `policy.toml`; o servidor relê sozinho
Revogar um certificado	Administrador da CA	`ca revoke` e copiar `revoked.txt` para a VM; vale na hora
Renovar certificados	Administrador da CA	A cada 397 dias, com `ca issue --replace`
Conferir a auditoria	Operador	`audit-verify`
Atualizar o app desktop	Cada usuário	Baixar da página de Releases, conferir o SHA-256 e instalar por cima

8. Limitações e próximos passos

- **Revisão de segurança externa** do servidor antes de guardar credenciais de produção.
- **Memória:** com o servidor desbloqueado, quem tiver root ou administrador na VM do cofre consegue ler os segredos. A VM deve rodar só este serviço, com poucos acessos.
- **Provedor da VPS:** tem acesso físico às VMs, inclusive à memória. Avaliar se isso é aceitável.
- **Pendências do MVP:** dividir a senha de desbloqueio entre várias pessoas (Shamir), encaminhamento automático dos logs e revogação sem cópia manual.
- **Compatibilidade:** cofres salvos pela 1.1.0 não abrem na 1.0.0. Atualize todos os computadores.
- **Instalador sem assinatura digital:** o Windows pode mostrar um aviso. Confira o SHA-256 antes de instalar.

> **Mais detalhes:** repositório privado **github.com/ivamgf/app_vault_konektron_server**. Instalação e uso do desktop no README; implantação, CA, comandos e API do servidor em docs/SERVIDOR.md.